

Mapeo de preguntas de la encuesta a requisitos normativos y marcos de referencia

Bloque / Pregunta	Tema principal	ISO/IEC 27001:2022 (cláusula / Anexo A)	ISO/IEC 27004 / Guías ISACA / otros	Comentario de alineamiento
1.1-1.4	Contexto y alcance de la organización	4 (Contexto), 5 (Liderazgo)	ISO 27004 – definición de contexto de medición [web:13]	Proporciona metadatos para interpretar indicadores en función del tipo y tamaño.
2.1-2.5	Sistema formal de indicadores y gobierno del SGSI	5.1, 5.3, 9.1	ISO 27004; ISACA KPI Guide 2024 [web:13]	Explora si se cumple la exigencia de medir desempeño y eficacia del SGSI.
3.1-3.5	Metodología de diseño de KPIs/KRIs	6.2, 6.3, 9.1	ISO 27004; ISMS.online KPIs [web:31][web:33]	Indaga uso de criterios formales (SMART) y referencias externas.
4.1-4.4	Indicadores estratégicos y ROI	5.2, 6.2, 9.1	ISACA KPI Guide 2024 [web:13] [web:34]	Cubre madurez del SGSI y retorno de inversión en seguridad.
5.1-5.4	Gestión de riesgos y KRIs	6.1, 6.2; Anexo A (controles de riesgo)	ISO 27004 – métricas de riesgo [web:13][web:33]	Relaciona indicadores con desempeño del proceso de gestión de riesgos.
6.1-6.4	Vulnerabilidades, parches y controles técnicos	Anexo A (A.5-A.8)	Plantillas KPI técnicas 27001 [web:4][web:31]	Miden eficacia de controles técnicos y tiempos de respuesta.
7.1-7.4	Incidentes, SOC, detección	8.1, 8.2, 8.3; Anexo A (incidentes, monitorización)	ISO 27004; ENISA Threat Landscape [web:16]	Alinea indicadores de incidentes con prácticas de reporte y monitorización.
8.1-8.4	Concienciación, formación, comportamiento	7.2, 7.3; Anexo A (concienciación)	ISO 27004; guías de KPIs de formación [web:13]	Miden eficacia de medidas organizativas y cultura de seguridad.

9.1-9.3	Continuidad y resiliencia	8.4; Anexo A (continuidad de negocio)	ENISA resiliencia; ISO 27004	Enlaza indicadores de pruebas de continuidad con objetivos de RTO/RPO.
10.1-10.3	Proveedores y cadena de suministro	Anexo A (relaciones con proveedores)	NIS2 – cadena de suministro [web:22]	Refleja nivel de control y medición sobre terceros críticos.
11.1-11.3	Regulación (NIS2, GDPR, etc.)	6.1-6.3, 9.1 (cumplimiento)	NIS2; ENISA guidance [web:20][web:26]	Evalúa integración de indicadores ISO con requisitos regulatorios y de reporte.
12.1-12.4	Automatización y calidad de datos	7.5, 9.1	Continuous compliance & KPIs [web:7] [web:31]	Cubre madurez de la función de medición y confiabilidad de los datos.
13.1-13.4	Reporte, comunicación y uso	5.1, 5.2, 9.3	ISACA – de medición a gestión [web:34]	Indaga si los indicadores se usan efectivamente en la toma de decisiones.
14.1-14.3	Visión futura y nivel de madurez	10 (Mejora)	ISACA KPI Guide; modelos de madurez [web:13]	Permite ubicar la organización en niveles 1-5 de madurez de medición.